

Cloud Security Quick Scan Report

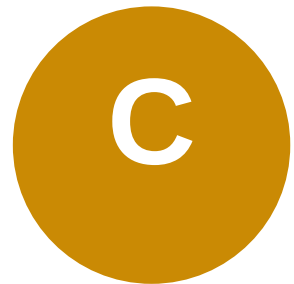
Assessment against ISO/IEC 27001:2022 Annex A

Noordkust Logistics NV

Scan date: 02 October 2026

Scope: Microsoft 365 / Entra ID, Microsoft Azure, Amazon Web Services, GitHub

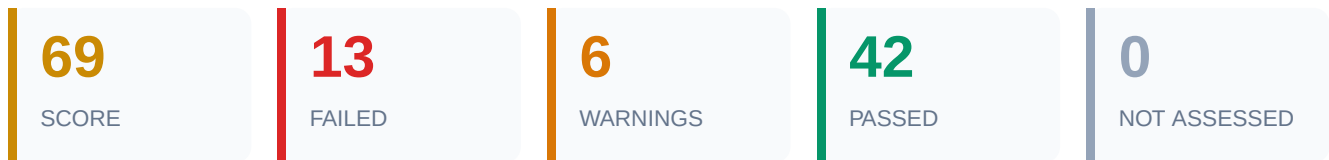
Report generated: 02 October 2026



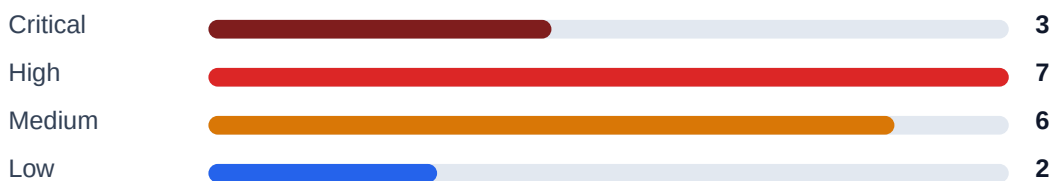
Score 69/100

Executive summary

Noordkust Logistics NV was assessed with 62 automated, read-only checks across 4 system(s). The overall security score is 69/100 (grade C). 2 critical and 6 high severity issue(s) need prompt attention. Based on the organisation context the risk profile is HIGH, which determined the evaluation criteria and the weighting of the score.



Findings by severity



Score by security domain



Compared to the previous scan

Previous scan on 18 September 2026 scored 51 (grade D); now 69 (grade C). 14 issue(s) resolved, 0 new, 20 persisting.

Risk profile

Level: HIGH | Sector: Transport / Logistics | Employees: 51-250

Regulatory context: NIS2 (important entity), ISO 27001 (certified or target)

Drivers: Organisation size widens the attack surface; NIS2 important entity; Sensitive data processed; Internet-facing services; Remote workforce relies on cloud identity; IT (partly) managed by a third party; Develops software in-house; Previous security incidents; Limited security maturity.

ISO/IEC 27001:2022 Annex A assessment

Each automated check is mapped to the Annex A control it provides evidence for (primary) and related controls (secondary). The verdict reflects technical evidence only; organisational aspects of a control (policies, procedures, awareness) are outside the scope of an automated scan.

14 EFFECTIVE

7 PARTIALLY EFFECTIVE

10 NOT EFFECTIVE

0 NOT ASSESSED

Control	Title	Verdict	Score
A.5.7	Threat intelligence	Effective	100%
A.5.9	Inventory of information and other associated assets	Not effective	13%
A.5.14	Information transfer	Effective	100%
A.5.15	Access control	Partially effective	65%
A.5.16	Identity management	Effective	100%
A.5.17	Authentication information	Partially effective	59%
A.5.18	Access rights	Partially effective	75%
A.5.19	Information security in supplier relationships	Effective	100%
A.5.23	Information security for use of cloud services	Effective	100%
A.5.24	Incident management planning and preparation	Effective	100%
A.5.25	Assessment and decision on information security events	Effective	100%
A.5.28	Collection of evidence	Effective	100%
A.5.34	Privacy and protection of PII	Effective	100%
A.8.2	Privileged access rights	Not effective	36%
A.8.3	Information access restriction	Partially effective	98%
A.8.4	Access to source code	Not effective	63%
A.8.5	Secure authentication	Not effective	69%
A.8.7	Protection against malware	Not effective	0%
A.8.8	Management of technical vulnerabilities	Not effective	18%
A.8.9	Configuration management	Not effective	31%
A.8.12	Data leakage prevention	Partially effective	99%
A.8.13	Information backup	Effective	100%
A.8.15	Logging	Effective	100%
A.8.16	Monitoring activities	Not effective	67%
A.8.20	Networks security	Not effective	75%
A.8.21	Security of network services	Effective	100%
A.8.22	Segregation of networks	Partially effective	50%

Control	Title	Verdict	Score
A.8.24	Use of cryptography	Effective	100%
A.8.25	Secure development life cycle	Not effective	33%
A.8.28	Secure coding	Effective	100%
A.8.32	Change management	Partially effective	80%

Priorities

Top risks

CRITICAL	No access keys for the root account	AWS production A.8.2
CRITICAL	Root account protected with MFA	AWS production A.8.5
CRITICAL	MFA enforced for all users	Noordkust Microsoft 365 A.8.5
HIGH	Between 2 and 4 Global Administrators	Noordkust Microsoft 365 A.8.2
HIGH	Least-privilege base permissions	GitHub organisation A.8.4
HIGH	Microsoft Defender for Cloud plans enabled	Noordkust Azure A.8.16
HIGH	No admin ports open to the internet	AWS production A.8.20
HIGH	No open critical/high Dependabot alerts	GitHub organisation A.8.8
HIGH	Read-only default workflow token	GitHub organisation A.8.25
HIGH	Phishing-resistant MFA for administrators	Noordkust Microsoft 365 A.8.2

Quick wins (low effort, meaningful impact)

CRITICAL	No access keys for the root account	AWS production A.8.2
CRITICAL	Root account protected with MFA	AWS production A.8.5
HIGH	Between 2 and 4 Global Administrators	Noordkust Microsoft 365 A.8.2
HIGH	Microsoft Defender for Cloud plans enabled	Noordkust Azure A.8.16
HIGH	Read-only default workflow token	GitHub organisation A.8.25
MEDIUM	AWS Config recording enabled	AWS production A.8.9

Detailed findings

CRITICAL

FAIL

No access keys for the root account

Amazon Web Services | AWS production | ISO 27001: A.8.2 Privileged access rights, A.5.17 Authentication information | AWS CIS 1.4

Programmatic access keys for the root user cannot be scoped down and are a high-value target.

Result: Root account has active access keys.

Affected resources (1)

- root

Recommendation (effort: low)

Delete all root access keys and use IAM roles with least privilege for automation.

CRITICAL

FAIL

Root account protected with MFA

Amazon Web Services | AWS production | ISO 27001: A.8.5 Secure authentication, A.8.2 Privileged access rights | AWS CIS 1.5 | NIS2 Art. 21(2)(j)

The AWS account root user has unrestricted access. It must be protected with multi-factor authentication (preferably a hardware key).

Result: Root account does not have MFA enabled.

Affected resources (1)

- root

Recommendation (effort: low)

Sign in as root, open Security credentials and assign an MFA device (FIDO2 security key recommended). Store the recovery procedure in a break-glass process.

CRITICAL

WARNING

MFA enforced for all users

Microsoft 365 / Entra ID | Noordkust Microsoft 365 | ISO 27001: A.8.5 Secure authentication, A.5.17 Authentication information | M365 CIS 5.2.2.2 | NIS2 Art. 21(2)(j)

Security Defaults or an enabled Conditional Access policy must require MFA for all users on all cloud apps.

Result: The policy 'CA001 - Require MFA - all users' exists but is in report-only mode.

Affected resources (1)

- CA001 - Require MFA - all users (enabledForReportingButNotEnforced)

Recommendation (effort: medium)

Enable a Conditional Access policy "Require MFA for all users" (all cloud apps, exclude only emergency access accounts), or turn on Security Defaults for tenants without Entra ID P1.

HIGH FAIL

Between 2 and 4 Global Administrators

Microsoft 365 / Entra ID | Noordkust Microsoft 365 | ISO 27001: A.8.2 Privileged access rights, A.5.18 Access rights | M365 CIS 1.1.3

Too many Global Administrators increase exposure; fewer than two risks lock-out.

Result: 6 active Global Administrators (recommended 2-4).

Affected resources (6)

- admin.pieters@noordkust.example
- k.janssens@noordkust.example
- it-support@noordkust.example
- l.maes@noordkust.example
- breakglass01@noordkust.example
- msp-partner@noordkust.example (guest of the managed service provider)

Recommendation (effort: low)

Reduce Global Administrators to 2-4 (including emergency access accounts) and delegate least-privileged roles instead.

HIGH FAIL

Least-privilege base permissions

GitHub | GitHub organisation | ISO 27001: A.8.4 Access to source code, A.5.15 Access control

Base permission write/admin gives every member write access to every repository.

Result: Base permission is "write" for all members.

Recommendation (effort: medium)

Set base permissions to "Read" or "No permission" and grant write access through teams.

HIGH FAIL

Microsoft Defender for Cloud plans enabled

Microsoft Azure | Noordkust Azure | ISO 27001: A.8.16 Monitoring activities, A.8.7 Protection against malware, A.8.8 Management of technical vulnerabilities | Azure CIS 3.1

Defender plans for servers, storage, key vault and databases provide threat detection and vulnerability assessment.

Result: 1 subscription(s) have no key Defender plans enabled.

Affected resources (2)

- noordkust-prod (not enabled: VirtualMachines, StorageAccounts, KeyVaults, Arm, SqlServers)
- noordkust-dev (not enabled: KeyVaults, SqlServers)

Recommendation (effort: low)

Enable the Defender plans matching deployed workloads (at least Servers, Storage, Key Vault, Resource Manager).

HIGH FAIL

No admin ports open to the internet

Amazon Web Services | AWS production | ISO 27001: A.8.20 Networks security, A.8.22 Segregation of networks | AWS CIS 5.2 | NIS2 Art. 21(2)(e)

Security groups allowing SSH, RDP or database ports from 0.0.0.0/0 or ::/0 are a common initial access vector.

Result: 3 security group rule(s) expose admin/database ports to the internet.

Affected resources (3)

- tms-windows-app (eu-west-1) (ports 3389)
- bastion-legacy (eu-west-1) (ports 22)
- reporting-db (eu-west-1) (ports 5432)

Recommendation (effort: medium)

Restrict ingress to known IP ranges, or remove it and use SSM Session Manager or a VPN / zero-trust access instead.

HIGH **FAIL**

No open critical/high Dependabot alerts

GitHub | GitHub organisation | ISO 27001: A.8.8 Management of technical vulnerabilities, A.8.25 Secure development life cycle | NIS2 Art. 21(2)(e)

Open vulnerable dependency alerts of critical or high severity indicate unpatched known vulnerabilities.

Result: 11 open critical/high Dependabot alerts across 3 repositories.

Affected resources (3)

- noordkust-demo/driver-app (4 critical, 3 high)
- noordkust-demo/route-planner (0 critical, 3 high)
- noordkust-demo/website (0 critical, 1 high)

Recommendation (effort: medium)

Enable Dependabot security updates, triage and fix open critical and high alerts; set an SLA for remediation.

HIGH **FAIL**

Read-only default workflow token

GitHub | GitHub organisation | ISO 27001: A.8.25 Secure development life cycle, A.8.2 Privileged access rights

A default GITHUB_TOKEN with write permissions amplifies the impact of a compromised workflow.

Result: Default GITHUB_TOKEN has read/write permissions.

Recommendation (effort: low)

Set default workflow permissions to "Read repository contents" and disallow Actions from approving pull requests.

HIGH **WARNING**

Phishing-resistant MFA for administrators

Microsoft 365 / Entra ID | Noordkust Microsoft 365 | ISO 27001: A.8.2 Privileged access rights, A.8.5 Secure authentication | M365 CIS 5.2.2.1

Administrative roles should be covered by Conditional Access requiring (phishing-resistant) MFA.

Result: Administrators require MFA, but not a phishing-resistant authentication strength.

Affected resources (1)

- CA001 - Require MFA - all users (enabled)

Recommendation (effort: medium)

Create a Conditional Access policy targeting directory roles that requires the "Phishing-resistant MFA" authentication strength.

MEDIUM **FAIL**

Access keys rotated within 90 days

Amazon Web Services | AWS production | ISO 27001: A.5.17 Authentication information | AWS CIS 1.14

Long-lived access keys increase the window of opportunity when leaked (e.g. in source code).

Result: 3 active access key(s) older than 90 days.

Affected resources (3)

- ci-deploy (key 1 rotated 2024-03-11)
- backup-sync (key 1 rotated 2023-11-02)
- tms-integration (key 2 rotated 2025-01-20)

Recommendation (effort: medium)

Rotate or remove access keys older than 90 days. Prefer IAM roles and short-lived credentials (OIDC federation for CI/CD).

MEDIUM

FAIL

AWS Config recording enabled

Amazon Web Services | AWS production | ISO 27001: A.8.9 Configuration management, A.5.9 Inventory of information and other associated assets, A.8.32 Change management | AWS CIS 3.3

AWS Config records configuration changes, which supports asset inventory, change tracking and investigations.

Result: AWS Config is not recording in any region.

Recommendation (effort: low)

Enable AWS Config recorders in all used regions with global resource recording in one region.

MEDIUM

FAIL

EC2 instances require IMDSv2

Amazon Web Services | AWS production | ISO 27001: A.8.9 Configuration management | AWS CIS 5.6

IMDSv1 is susceptible to SSRF-based credential theft. IMDSv2 requires session tokens.

Result: 5 of 9 instances allow IMDSv1.

Affected resources (5)

- tms-app-01 (eu-west-1)
- tms-app-02 (eu-west-1)
- sftp-gateway (eu-west-1)
- reporting-worker (eu-west-1)
- bastion-legacy (eu-west-1)

Recommendation (effort: medium)

Set HttpTokens=required on instances and launch templates; set the account default to IMDSv2.

MEDIUM

FAIL

Limited organisation owners

GitHub | GitHub organisation | ISO 27001: A.8.2 Privileged access rights

Organisation owners have full control. Keep the number small.

Result: 7 organisation owners.

Affected resources (7)

- pieters-nk
- kjanssens
- devops-bot
- lmaes
- rvdb
- msp-dev
- ci-admin

Recommendation (effort: low)

Reduce owners to 2-4 people and use the security manager or custom roles for delegated duties.

MEDIUM**FAIL**

Privileged accounts are cloud-only

Microsoft 365 / Entra ID | Noordkust Microsoft 365 | ISO 27001: A.8.2 Privileged access rights | M365 CIS 1.1.1

Synchronised on-premises accounts in privileged roles allow an AD compromise to pivot to the cloud tenant.

Result: 2 privileged account(s) are synchronised from on-premises AD.

Affected resources (2)

- k.janssens@noordkust.example (synchronised from on-premises)
- l.maes@noordkust.example (synchronised from on-premises)

Recommendation (effort: medium)

Use dedicated cloud-only accounts for Entra ID administrative roles.

MEDIUM**WARNING**

Privileged Identity Management in use

Microsoft 365 / Entra ID | Noordkust Microsoft 365 | ISO 27001: A.8.2 Privileged access rights

Just-in-time role activation reduces standing privileged access.

Result: No PIM eligible role assignments: privileged roles are permanently assigned.

Recommendation (effort: medium)

Convert permanent privileged role assignments into PIM eligible assignments with approval and MFA on activation.

LOW**WARNING**

Guest directory access restricted

Microsoft 365 / Entra ID | Noordkust Microsoft 365 | ISO 27001: A.8.3 Information access restriction | M365 CIS 5.1.6.3

Guests should not be able to enumerate the full directory.

Result: Guests have limited access to directory objects (default); consider the most restrictive setting.

Recommendation (effort: low)

Set guest user access to "Guest user access is restricted to properties and memberships of their own directory objects".

LOW**WARNING**

Users cannot register applications

Microsoft 365 / Entra ID | Noordkust Microsoft 365 | ISO 27001: A.5.15 Access control, A.8.9 Configuration management | M365 CIS 5.1.2.2

Default users being able to create app registrations increases shadow IT and persistence options.

Result: All users can register applications.

Recommendation (effort: low)

Set "Users can register applications" to No and assign Application Developer to those who need it.

LOW

WARNING

RISK ACCEPTED

Weak MFA methods (SMS / voice) disabled

Microsoft 365 / Entra ID | Noordkust Microsoft 365 | ISO 27001: A.8.5 Secure authentication

SMS and voice calls are vulnerable to SIM swapping and interception.

Result: Weak methods enabled: Sms, Voice.

Affected resources (2)

- Sms
- Voice

Recommendation (effort: low)

Disable SMS and voice call in the Authentication methods policy after migrating users to Microsoft Authenticator or passkeys.

Triage note: SMS stays enabled for warehouse staff without company smartphones until Q2 2027. Compensating control: sign-in restricted to the warehouse network via Conditional Access.

INFO

WARNING

Public repositories reviewed

GitHub | GitHub organisation | ISO 27001: A.5.9 Inventory of information and other associated assets, A.8.12 Data leakage prevention

Lists public repositories so the owners can confirm each is intentionally public.

Result: 2 public repositories: confirm they are intended to be public.

Affected resources (2)

- noordkust-demo/website
- noordkust-demo/tms-api-client (contains internal hostnames in README)

Recommendation (effort: low)

Confirm each public repository is intended to be public; archive or make private otherwise.

Scope, method and limitations

Systems in scope

Noordkust Microsoft 365 - Microsoft 365 / Entra ID - Noordkust Logistics NV
(0f1e2d3c-4b5a-4968-8776-655443322110)
Noordkust Azure - Microsoft Azure - 2 subscription(s)
AWS production - Amazon Web Services - AWS account 111122223333
GitHub organisation - GitHub - github.com/noordkust-demo

Method

The assessment was performed between 02 October 2026 and 02 October 2026 using read-only API access (Microsoft Graph, Azure Resource Manager, AWS APIs and the GitHub REST API). No changes were made to the environments. Evaluation criteria were selected based on the organisation's risk profile and reviewed before the scan. Scores are weighted by severity and by the domain weights derived from the risk profile.

Limitations

This is a point-in-time, automated configuration review. It does not include penetration testing, review of on-premises systems, endpoint configuration, or organisational controls (policies, processes, awareness). Results depend on the permissions and licences available to the scanning identity; checks that could not be evaluated are listed below. A passed check is not a guarantee of security.

Access revocation

Credentials handling for this scan: secrets were deleted automatically when the scan completed. We recommend removing the scanner access (IAM role, app consent / registration, Azure role assignments, GitHub token) once it is no longer needed.

Criteria excluded from scope

Access requires managed or compliant devices (Microsoft 365 / Entra ID): Intune roll-out is planned for Q1 2027; agreed out of scope for this assessment.

Customer managed KMS keys rotated (Amazon Web Services): Only AWS managed keys are used for production data according to the IT team.

Passed checks

PASS No publicly accessible S3 buckets (AWS production, A.8.3)
PASS Organisation requires 2FA (GitHub organisation, A.8.5)
PASS Account-level S3 Block Public Access (AWS production, A.8.3)
PASS Console IAM users have MFA (AWS production, A.8.5)
PASS Default branches protected (GitHub organisation, A.8.32)
PASS GuardDuty threat detection enabled (AWS production, A.8.16)
PASS Legacy authentication blocked (Noordkust Microsoft 365, A.8.5)
PASS Multi-region CloudTrail with log validation (AWS production, A.8.15)
PASS No IAM users with direct AdministratorAccess (AWS production, A.8.2)
PASS No management ports open to the internet (Noordkust Azure, A.8.20)
PASS No over-privileged application permissions (Noordkust Microsoft 365, A.8.2)
PASS No publicly accessible RDS instances (AWS production, A.8.20)
PASS Secret scanning enabled (GitHub organisation, A.8.28)
PASS SQL servers not open to all IPs (Noordkust Azure, A.8.20)
PASS Storage accounts disallow public blob access (Noordkust Azure, A.8.3)
PASS Users registered for MFA (Noordkust Microsoft 365, A.8.5)
PASS Activity log exported (Noordkust Azure, A.8.15)
PASS EBS encryption by default (AWS production, A.8.24)
PASS GitHub Actions restricted to trusted actions (GitHub organisation, A.5.19)
PASS Guest invitations restricted (Noordkust Microsoft 365, A.5.15)

PASS Key Vault purge protection enabled (Noordkust Azure, A.8.24)
PASS Limited subscription Owners (Noordkust Azure, A.8.2)
PASS Members cannot create public repositories (GitHub organisation, A.8.12)
PASS No open critical/high code scanning alerts (GitHub organisation, A.8.28)
PASS No stale enabled accounts (90+ days) (Noordkust Microsoft 365, A.5.18)
PASS No unused credentials (90+ days) (AWS production, A.5.18)
PASS RDS automated backups retained 7+ days (AWS production, A.8.13)
PASS RDS storage encrypted (AWS production, A.8.24)
PASS Secret push protection enabled (GitHub organisation, A.8.28)
PASS Security Hub enabled (AWS production, A.8.16)
PASS Sign-in and user risk policies (Noordkust Microsoft 365, A.8.16)
PASS SPF and DMARC enforced on mail domains (Noordkust Microsoft 365, A.5.14)
PASS Storage enforces HTTPS and TLS 1.2+ (Noordkust Azure, A.8.24)
PASS User consent to applications restricted (Noordkust Microsoft 365, A.5.19)
PASS Deploy keys are read-only (GitHub organisation, A.5.17)
PASS IAM Access Analyzer enabled (AWS production, A.5.18)
PASS Microsoft Secure Score (Noordkust Microsoft 365, A.8.9)
PASS Outside collaborators reviewed (GitHub organisation, A.5.19)
PASS Private repository forking restricted (GitHub organisation, A.8.12)
PASS Security contact configured (Noordkust Azure, A.5.24)
PASS Strong IAM password policy (AWS production, A.5.17)
PASS Webhooks use verified HTTPS (GitHub organisation, A.8.21)